

Control Implementation Procedures : VertexOne Digital Services

A.8.2 Privileged Access Request & Review Procedure

1. Requestor submits a privileged access request specifying the system and business justification.
2. CISO or delegate approves or denies the request within 2 business days.
3. IT Operations provisions time-bound, just-in-time access.
4. GRC Manager reviews all active privileged access quarterly and revokes unused grants.

A.8.1 Endpoint Enrollment & Compliance Procedure

1. New devices are enrolled in MDM before first access to company systems.
2. Baseline configuration, including disk encryption, screen lock, and patch level, is applied automatically.
3. Non-compliant devices are restricted from production access until remediated.

A.8.16 SIEM Alert Triage Procedure

1. IT Operations reviews the SIEM alert queue each business day.
2. Alerts are triaged as False Positive, Informational, or Requires Investigation.
3. Investigated alerts are logged with resolution notes and closed within 5 business days.

A.8.8 Vulnerability Scanning & Patch SLA Procedure

1. Automated dependency and infrastructure scans run weekly.
2. Findings are classified by severity: Critical, High, Medium, or Low.
3. Critical findings are remediated within 15 days; High findings within 30 days.
4. Engineering Lead reports SLA compliance monthly.

A.8.13 Backup & Restoration Testing Procedure

1. Automated backups run nightly for all in-scope systems.
2. A restoration test is performed quarterly against a non-production environment.
3. Results, including pass/fail status and time to restore, are logged and reported to IT Operations leadership.

A.5.19 Vendor Security Assessment Procedure

1. Critical vendors are issued a standardized security questionnaire annually.
2. Identified gaps are logged and tracked to remediation with the vendor.
3. Security addenda are added to contracts at the next renewal or amendment opportunity.

A.8.9 Secure Baseline & Drift Remediation Procedure

1. Secure configuration baselines are defined for each in-scope platform.
2. Automated scans check for configuration drift weekly.
3. Deviations are remediated within 10 business days or formally risk-accepted.

A.5.24 Incident Response & Escalation Procedure

1. Employees report suspected incidents through the designated reporting channel.
2. GRC Manager triages and classifies severity within 4 hours.
3. High-severity incidents are escalated to the CISO and Risk Committee immediately.
4. A post-incident review is conducted within 10 business days of closure.

A.8.24 Encryption & Key Management Procedure

1. Encryption at rest is enabled by default for all new storage resources.
2. Encryption keys are managed centrally with defined rotation intervals.
3. Key access is logged and reviewed quarterly.

A.8.7 EDR Deployment & Threat Response Procedure

1. EDR agents are deployed to all endpoints, servers, and legacy systems as part of onboarding.
2. Detected threats trigger automatic quarantine and an alert to IT Operations.
3. EDR coverage is reconciled monthly against the full asset inventory to identify gaps.

Prepared by: Junior GRC Analyst